

REPORTE EJECUTIVO DE GESTIÓN DE RIESGOS

Evaluación de Ciberseguridad y Continuidad Operativa de TI

Dirigido a Directorio de la Clínica

1. RESUMEN EJECUTIVO

Durante el presente ciclo de evaluación se realizó un análisis integral sobre la infraestructura tecnológica y los activos de información de la clínica utilizando la plataforma **SimpleRisk**. El objetivo principal consistió en identificar las amenazas que atentan contra la continuidad asistencial, la integridad de las Historias Clínicas Digitales (HCD) y el cumplimiento de las normativas de protección de datos de pacientes.

Se identificó que el principal vector de vulnerabilidad reside en la posibilidad de interrupción del sistema HIS por ciberataques (Ransomware) y la fuga de credenciales administrativas por Phishing. El riesgo global de la institución se ubica en un nivel **Alto**, requiriendo medidas de mitigación técnica y organizativa inmediatas para garantizar la continuidad operativa.

2. TOP 5 RIESGOS POR NIVEL

Evaluación cualitativa sobre matriz de impacto y probabilidad (5 × 5):

1°	R-01	Ransomware en Servidores HCD / HIS	Disponibilidad / Confidencialidad	20 - Crítico
2°	R-02	Fuga de Datos Médicos por Phishing	Confidencialidad / Legal	16 - Alto
3°	R-03	Acceso No Autorizado por Credenciales Débiles	Confidencialidad / Integridad	12 - Alto
4°	R-04	Corte de Energía en Centro de Cómputos	Disponibilidad / Operativo	10 - Medio-Alto
5°	R-05	Pérdida o Robo de Dispositivos Móviles	Confidencialidad	9 - Medio

3. ESTADO DE LOS PLANES DE ACCIÓN

A continuación se detalla el estado de implementación de los **3 planes de mitigación** definidos e ingresados en la plataforma SimpleRisk:

1.
Plan de Mitigación R-01 (Infección por Ransomware): *[En Progreso]*
Implementación de estrategia de respaldos inmutables (3-2-1 Off-site) y despliegue de agentes EDR en servidores críticos.
2.
Plan de Mitigación R-02 / R-03 (Seguridad de Identidad y Acceso): *[En Planificación]* Despliegue de Autenticación de Doble Factor (2FA) obligatoria e integración con LDAP para prevenir Phishing y accesos no autorizados.
3.
Plan de Mitigación R-04 (Continuidad Eléctrica): *[Mitigado / Monitoreado]*
Plan de mantenimiento preventivo para la UPS centralizada y verificación del conmutador del grupo electrógeno.

4. RECOMENDACIONES PRIORITARIAS

- **Aprobación de Presupuesto para Respaldos Off-site Inmutables:** Priorizar la adquisición de almacenamiento en nube aislado para garantizar la restauración del sistema HCD en menos de 4 horas ante una contingencia.
- **Despliegue Obligatorio de 2FA:** Hacer obligatorio el uso de segundo factor de autenticación para todo el personal asistencial y administrativo que acceda a la red de la clínica.
- **Programa Permanente de Concientización:** Iniciar jornadas trimestrales de capacitación sobre ciberseguridad y simulaciones de Phishing para el personal médico.
- **Monitoreo y Alertas en Tiempo Real:** Mantener activa la integración automatizada de alertas críticas vía Webhook hacia el equipo de soporte técnico para una respuesta inmediata a incidentes.

Felipe Villar Zuloaga

Seguridad — Universidad Champagnat